

DPDP COMPLIANCE AUDIT

ai-email-drafter

Digital Personal Data Protection Act 2023

82/100

Grade B

Adequate

Scanned: 25 March 2026

Files indexed: 8

Languages: express, dotenv, cors, nodemailer, axios, react

CONFIDENTIAL — Internal Use Only

DPDP Compliance Scan Report

The application collects recipient email addresses, subjects, and email content. The biggest DPDP risk is the transmission and potential storage of recipient email addresses and content without explicit consent mechanisms visible in the code.

Validation Summary Rule findings: 5 confirmed, 3 false positives suppressed • AI gaps: 1 dual-validated • Score: 82 (rules) → 82 (integrated)

Total findings: 6

HIGH: 1

MEDIUM: 1

INFO: 3

Tech Stack: express, dotenv, cors, nodemailer, axios

Risk Profile: The application collects recipient email addresses, subjects, and email content. The biggest DPDP risk is the transmission and potential storage of recipient email addresses and content without explicit consent mechanisms visible in the code.

Compliance score by section

DPDP Section	Weight	Score	Status
Section 6	22	22/22 (100%)	PASS
Section 6(6)	8	8/8 (100%)	PASS
Section 8(1)	18	0/18 (0%)	FAIL
Section 8	10	10/10 (100%)	PASS
Section 8(3)	8	8/8 (100%)	PASS
Section 8(4)	8	8/8 (100%)	PASS
Section 8(6)	8	6.8/8 (85%)	PASS
Section 9	6	6/6 (100%)	PASS
Section 11	6	6/6 (100%)	PASS
Section 16	4	4/4 (100%)	PASS
Section 5	2	2/2 (100%)	PASS
Section 13 — Grievance Redressal		4/4 (100%)	PASS

Estimated Total Remediation Effort: 1.1–3.9 engineering days

Data Flow Analysis

The following PII flow signals were inferred via static analysis (import/call adjacency). These are heuristic code-path chains, not proven runtime traces. Use them to guide developer review (confirm actual request → handler → service → database paths in your app).

Flow 1: Application Logs

PII fields: email, address, password

emailRoutes.js → emailController.js

Flow 2: Application Logs

PII fields: email

index.js

Flow 3: Application Logs

PII fields: email, address, password

index.js → emailRoutes.js → emailController.js

Flow 4: Application Logs

PII fields: email

DraftEmail.jsx

Rule	Section	Severity	File
NO_BREACH_ALERTING	Section 8(6) — Breach	LOW	N/A
NO_THIRD_PARTY_DETECTED	Section 5 — Notice	INFO	N/A
NO_THIRD_PARTY_DATA_SHARING	Section 5 — Purpose Limitation	INFO	N/A
NO_CROSS_BORDER_DETECTED	Section 16 — Cross-Border Transfer	INFO	N/A
PLAINTEXT_PII_IN_LOGS	Section 8(1) — Security	HIGH	frontend/src/components/DraftEmail.jsx
	Section 10 — Data Protection Officer	MEDIUM	

30-Day Remediation Roadmap

The following plan prioritises findings by severity and estimated effort. Complete Week 1 items before your next security review.

Week 1 — Critical (1–3 hours)

Fix immediately — these represent the highest legal exposure.

- Plaintext Pii In Logs — components/DraftEmail.jsx (1–3 hrs)

Week 2 — High Priority (2–8 hours)

Address within 2 weeks — short fixes with significant compliance impact.

- (2–8 hrs)

Week 4 — Advisory (2–6 hours)

Address before next compliance review.

- No Breach Alerting (2–6 hrs)

Total estimated remediation effort: 5–17 hours (0.6–2.1 engineering days)

Changes Since 2026-03-24

▼ Score: 90.0 → 82 (-8.0 points)

■ 3 new finding(s) introduced

— 5 finding(s) unchanged

New findings this scan:

- No Deletion Mechanism [HIGH]
- Consent Missing [HIGH]
- Consent Missing [HIGH]

Details

Finding 1 of 6

[Section 8(6) — Breach]

1. [LOW] NO_BREACH_ALERTING — N / A

Estimated fix time: 2–6 hours

Structured logging detected but no breach notification mechanism found. DPDP Section 8(6) requires notifying affected individuals and the Authority without undue delay when a breach occurs. Logging alone is insufficient — implement automated alerting (Sentry, PagerDuty, or equivalent) with escalation to a compliance team.

Risk:

The absence of a breach notification mechanism means that security incidents may not be detected or reported promptly. This hinders the ability to comply with DPDP Section 8(6) requirements for timely notification to affected individuals and the Authority.

Fix:

1. Integrate a third-party error tracking and alerting service (e.g., Sentry, Datadog, PagerDuty) into the backend application.
2. Configure the alerting service to monitor for critical errors, especially those related to data handling or security.
3. Set up notifications within the alerting service to escalate critical alerts to a designated compliance team or individual.
4. Ensure that the logging on line 27 in the frontend and any backend logging includes sufficient detail to diagnose potential breaches when alerts are triggered.

DPDP:

Section 8(6) — Breach

Example:

```
// Example using Sentry SDK in backend/index.js import * as Sentry from '@sentry/node';
Sentry.init({ dsn: process.env.SENTRY_DSN, integrations: [new Sentry.Integrations.Express({
app })], tracesSampleRate: 1.0, }); // The request handler must be the last middleware on the
app app.use(Sentry.Handlers.requestHandler()); // ... other middleware and routes ... //
Optional: Error handler for Sentry app.use(Sentry.Handlers.errorHandler());
```

Finding 2 of 6

[Section 5 — Notice]

2. [INFO] NO_THIRD_PARTY_DETECTED — N / A

No known third-party analytics or tracking SDKs detected in codebase.

Finding 3 of 6

[Section 5 — Purpose Limitation]

3. [INFO] NO_THIRD_PARTY_DATA_SHARING — N / A

No third-party data sharing detected.

Finding 4 of 6

[Section 16 — Cross-Border Transfer]

4. [INFO] NO_CROSS_BORDER_DETECTED — N / A

No foreign cloud or non-India region config detected.

Finding 5 of 6

[Section 8(1) — Security]

5. [HIGH] PLAINTEXT_PII_IN_LOGS — frontend / src / components / DraftEmail.jsx:18**Evidence snippet:** console.log('■ Draft Email:', res.data.draft);**Estimated fix time:** 1–3 hours

PII keyword appears in logging call. Personal data may be written to logs in plaintext.

Risk:

Personal data may be exposed in logs if the 'res.data.draft' contains PII and is logged without sanitization. This violates the requirement to protect personal data from unauthorized disclosure.

Fix:

1. Modify the console.log statement on line 20 to avoid logging sensitive data directly. Consider logging only non-PII fields or a summary.
2. Implement a data sanitization or masking mechanism before logging any data that might contain PII.
3. Review the 'res.data.draft' content in the backend controller to ensure PII is not being unnecessarily included or logged.

DPDP:

Section 8(1) — Security

Example:

```
const handleDraft = async () => { try { const res = await
axios.post('http://localhost:5000/api/email/draft', { to, subject, context }); // Example: Log
only a confirmation or summary, not the full draft console.log('■ Email draft generated
successfully. '); setResponse(res.data.draft); } catch (error) { console.error('■ Frontend
Axios error:', error); setResponse('Error generating email draft. Please try again later. '); }
};
```

Finding 6 of 6

[Section 10 — Data Protection Officer]

6. [MEDIUM] — CODEBASE-WIDE

No DPO/Grievance Officer contact exposed

AI-Identified Compliance Gaps

The following gaps were identified by AI analysis and cross-validated. These are advisory observations, not verified rule violations. Human review is required before acting on these findings.

[AI-INFERRED] No DPO/Grievance Officer contact exposed

Confidence: 82%

Section 10 — Data Protection Officer

The repository context and file analysis do not indicate any public-facing contact information for a Data Protection Officer or Grievance Officer, which is a requirement for data fiduciaries under DPDP. This information is typically found in privacy policies or 'contact us' sections, which are not visible in the provided code snippets or data flows.

Recommendation: Add a public-facing endpoint or section (e.g., in ``frontend/src/components/DraftEmail.jsx`` or a new dedicated component) that clearly displays the contact details for the designated Grievance Officer or DPO.